notion of mandatory security and must support flexible configuration of mandatory policies.

Mainstream commercial operating systems rarely support the principle of least privilege even in their discretionary access control architecture. Many operating systems only provide a distinction between a completely privileged security domain and a completely unprivileged security domain. Even in Microsoft Windows NT, the privilege mechanism fails to adequately protect against malicious programs because it does not limit the privileges that a program inherits from the invoking process based on the trustworthiness of the program.

Current microkernel-based research operating systems have tended to focus on providing primitive protection mechanisms which may be used to flexibly construct a higher-level security architecture. Many of these systems use kernel-managed capabilities as the underlying protection mechanism. However, typical capability architectures are inadequate for supporting mandatory access controls with a high degree of flexibility and assurance. Flask, a variant of the Fluke microkernel, provides a mandatory security framework similar to that of DTOS, a variant of the Mach microkernel; both systems provide mechanisms for mandatory access control and a mandatory policy framework.

Trusted Paths

A trusted path is a mechanism by which a user may directly interact with trusted software, which can only be activated by either the user or the trusted software and may not be imitated by other software. In the absence of a trusted path mechanism, malicious software may impersonate trusted software to the user or may impersonate the user to trusted software. Such malicious software could potentially obtain sensitive information, perform functions on behalf of the user in violation of the user's intent, or trick the user into believing that a function has been invoked without actually invoking it. In addition to supporting trusted software in the base system, the trusted path mechanism should be extensible to support the subsequent addition of trusted applications by a sys-